

모의해킹 프로세스

1. Information Gathering (정보 수집)

단계 (Phase)	구분	핵심 도구	필수 학습 공격 기법 및 이론 (Keywords)	학습 목표
1. Information Gathering (정보 수집)	OSINT (공개정보)	Google Dorks Shodan theHarvester	• Google Hacking :민감 파일(PDF, XLSX), 관리자 페이지 노출 탐색 • IoT Search :Shodan을 이용한 취약한 CCTV, 서버 식별	대상에 직접 접속하지 않고 정보를 캐내는 '비접촉' 정찰 기법 습득
	Active (능동수집)	whois dig dnsenum dnsrecon	• Zone Transfer (AXFR) :DNS 존 전송 공격 (서브도메인 전체 탈취) • Subdomain Enumeration :개발/테스트 서버 등 숨겨진 도메인 찾기	DNS 구조를 이해하고 공격 표면(Attack Surface)을 최대로 확장

OSINT (공개정보)

아카이브와 검색엔진 대상 (이미 수집된 데이터)

Google Hacking

: Google 검색 엔진의 고급 검색 기능(검색 연산자)을 이용해, 인터넷에 의도치 않게 노출된 민감 정보나 취약한 시스템을 찾아내는 기법

1) 검색 연산자(**Advanced Search Operators**) 악용

- Google은 특정 파일 형식, 특정 경로, 특정 도메인에 특화된 검색을 지원함.
- 공격자는 이것을 이용해 의도치 않게 공개된 설정파일, 로그파일, 백업파일 등을 찾을 수 있음.

예: **filetype:** / **site:** 같은 연산자 조합을 악용하는 방식

2) 공개된 디렉터리(**Browsable Directory**) 찾기

- 서버 설정이 잘못돼 디렉터리 목록이 그대로 보이는 경우가 있음.
- 공격자는 이를 통해 내부 자료 구조를 파악하거나, 파일을 다운로드하여 악용할 가능성이 있음.

3) 노출된 민감 정보 찾기

- 관리자 페이지
- 패스워드가 포함된 설정파일
- 내부용 문서
- 데이터베이스 덤프 파일

등이 검색에 잡힐 수 있음.

이 역시 서버 관리 부주의, 백업 파일 업로드, 클라우드 공개 범위 설정 오류 등의 이유로 일어남.

4) 취약한 웹 애플리케이션 버전 탐지

- 특정 소프트웨어 버전 문자열이 웹페이지의 하단 또는 **metadata**에 노출되는 경우가 있음.

****metadata** : 실제 데이터가 아니라, 데이터를 설명하는 속성 정보

- 공격자는 그 버전의 알려진 취약점을 바탕으로 추가 공격을 시도할 수 있음.

5) Google Dork Database(GHDB) 참고

공식적으로 알려진 Google Hacking 사례들을 모아둔 GHDB(Google Hacking Database)가 있음.

>> 실제 노출된 정보가 아니라, 어떤 유형의 잘못된 공개가 취약점을 일으키는지에 대한 분류와 경고 확인 가능.

<https://www.exploit-db.com/google-hacking-database>

IOT Search (사물인터넷 검색)

: 해커가 대상시스템을 직접 스캔(NMAP) 하지 않고, 검색엔진을 통해 인터넷이 연결된 취약한 기기(CCTV, 공유기, 산업제어시스템 등)를 찾아내는 비접촉 정보수집 기술

구분	설명
목표	웹페이지가 아닌 실제 물리적 장치 (웹캠, 라우터, 스마트 냉장고, 산업용 제어 시스템 등)를 식별합니다.
핵심 기술	포트 스캐닝, 배너 그라빙(Banner Grabbing), 프로토콜 분석 등을 통해 장치의 특성을 파악합니다.
주요 용도	보안 연구 (공개된 취약 장치 발견), 자산 관리 (자신의 네트워크에 연결된 모든 장치 확인), 위협 인텔리전스 수집.

****배너 그래빙(Banner Grabbing)** : 특정 네트워크 서비스나 애플리케이션에 연결하여 그 서비스가 자신을 소개할 때 보내는 식별 정보(배너)를 추출하는 행위

IoT 검색을 통한 정보 유형

- **장치 유형:** 웹캠, CCTV, 라우터, 프린터, NAS, SCADA/ICS 시스템 등
- **소프트웨어/버전:** 장치에서 실행되는 OS 및 서비스 버전 정보 (취약점 확인에 중요)
- **지리적 위치:** 장치가 위치한 대략적인 지리 정보
- **공개된 데이터:** 비밀번호가 설정되지 않아 공개된 웹캠 영상, FTP 서버 파일 목록 등